

# Computer Security: Principles and Practice

## Intrusion Detection

Chapter 8



# COMPUTER SECURITY DEFINITION (BY NIST)

Computer Security =



CIA Triad



Assets

Computer Security is composed of Measures and controls that ensure **Confidentiality**, **Integrity**, and **Availability** of **information system assets**

**Information system assets** = Hardware, Software, firmware and information (stored, processed and communicated)

# DEFINITIONS

## Security Intrusion

- Unauthorized act of bypassing the security mechanisms of a system

## Intrusion Detection

- A hardware or software function that gathers and analyzes information from various areas within a computer or a network to identify possible security intrusions

# CLASSES OF INTRUDERS

## Cyber criminals

Individuals or members of an **organized crime** group with a goal of **financial reward**

## Activists/ Hacktivists

Individuals or groups driven by **social** or **political** causes, often working as insiders or outsider attackers.

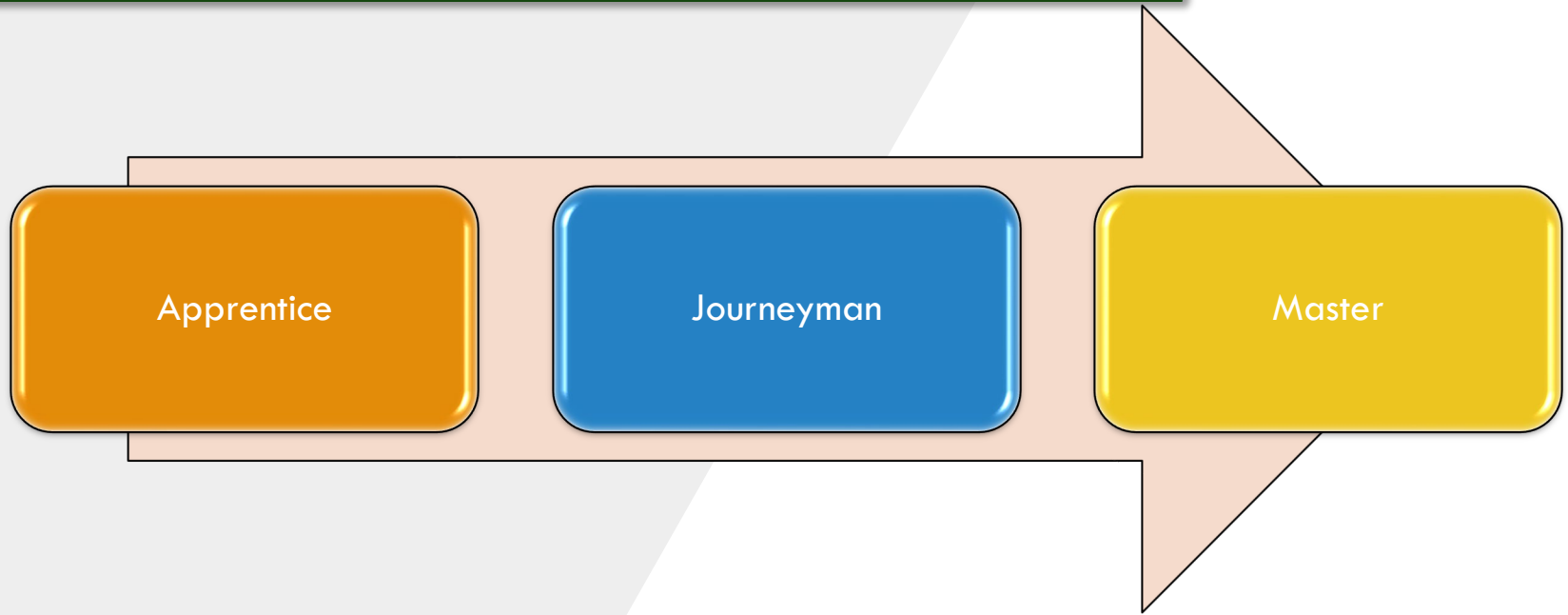
## State-Sponsored Organizations

Groups of hackers sponsored by governments to conduct espionage or sabotage activities

## Others

- Include **classic hackers** or crackers who are motivated by **technical challenge** or by **peer-group esteem** and **reputation**

# INTRUDER SKILL LEVELS



|                   |                                                                                                                                             |
|-------------------|---------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Apprentice</b> | Hackers with <b>minimal technical skill</b> who primarily use existing attack toolkits                                                      |
| <b>Journeyman</b> | Hackers with <b>sufficient technical skills to modify and extend attack toolkits</b> to use newly discovered, or purchased, vulnerabilities |
| <b>Master</b>     | Hackers with <b>high-level technical skills</b> capable of <b>discovering brand new categories of vulnerabilities</b>                       |

# EXAMPLES OF INTRUSION

Remote root  
compromise

Web server  
defacement

Guessing/cracking  
passwords

Copying  
databases  
containing credit  
card numbers

Viewing sensitive  
data without  
authorization

Running a packet  
sniffer

Distributing  
pirated software

Using an unsecured  
modem to access  
internal network

Impersonating an  
executive to get  
information

Using an  
unattended  
workstation

# INTRUDER BEHAVIOR

Target acquisition  
and information  
gathering



Initial access



Privilege  
escalation



Information  
gathering or  
system exploit



Maintaining  
access



Covering tracks

# INTRUDER BEHAVIOR

## Target acquisition & info gathering

Scanning social media for employee details

## Initial access

Phishing email with a malicious link, by exploiting a remote network vulnerability, by guessing weak authentication credentials used in a remote service or via the installation of malware on the system

## Privilege escalation

Exploiting a weak admin password

## Info gathering/system exploit

Extracting database records via SQL injection

## Maintaining access

Installing a backdoor for future entry or other malicious software , or addition of covert authentication credentials or other configuration changes to the system, to enable continued access by the attacker after the initial attack.

## Covering tracks

Deleting logs to erase evidence



# DEFINITIONS

## **Security Intrusion**

- Unauthorized act of bypassing the security mechanisms of a system

## **Intrusion Detection**

- A hardware or software function that gathers and analyzes information from various areas within a computer or a network to identify possible security intrusions

# INTRUSION DETECTION SYSTEM (IDS)

- Comprises of three logical components:

## 1) **Sensors** - collect data

- The input for a sensor may be any part of a system that could contain evidence of an intrusion.
- Types of input to a sensor includes network packets, log files, and system call traces.
- Sensors collect and forward this information to the analyzer.

## 2) **Analyzers** - determine if intrusion has occurred

- Analyzers receive input from one or more sensors or from other analyzers which may also be stored for future analysis and review
- The output may include evidence supporting the conclusion that an intrusion occurred.
- The analyzer may provide guidance about what actions to take as a result of the intrusion.

## 3) **User interface** - view output or control system behavior

- The user interface to an IDS enables a user to view output from the system or control the behavior of the system.

- An IDS may use a single sensor and analyzer, such as a classic HIDS on a host or NIDS in a firewall device.
- More sophisticated IDSs can use multiple sensors, across a range of host and network devices, sending information to a centralized analyzer and user interface in a distributed architecture.

# INTRUSION DETECTION SYSTEM (IDS)

IDSs are often classified based on the source and type of data analyzed, as:

- **Host-based IDS (HIDS)**
  - Monitors the characteristics of a single host and the events occurring within that host, such as process identifiers and the system calls they make, for evidence of suspicious activity.
  - Detect both **external** and **internal intrusions**
  - Can use either **anomaly** or **signature/heuristic approaches**
- **Network-based IDS (NIDS)**
  - Monitors network traffic and analyzes network, transport, and application protocols to detect suspicious activity.
- **Distributed or hybrid IDS**
  - Combines **data** from a number of sensors, often both **host** and **network**-based, in a central analyzer that is able to better identify and respond to intrusion activity.

# IDS REQUIREMENTS

- Because of the nature of the probabilities involved, it is very difficult to meet the standard of high rate of detections with a low rate of false alarms.

A desirable IDS must:

- **Run continually** – min human supervision
- **Be fault tolerant** - able to recover from system crashes and reinitializations.
- **Resist subversion** - monitor itself and detect if it has been modified by an attacker.
- **Impose a minimal overhead** on system
- **Configured according to system security policies**
- **Adapt to changes in systems and user** behavior over time
- **Scalable to monitor** a large numbers of hosts
- **Provide graceful degradation of service** - if some components of the IDS stop working for any reason, the rest of them should be affected as little as possible.
- **Allow dynamic reconfiguration** - the ability to reconfigure the IDS without having to restart it.

# ANALYSIS APPROACHES

## Anomaly detection

- Collects legitimate user behavior **data over time** and **analyzes** it to create a model.
- Then current observed behavior is analyzed to determine whether this behavior is that of a legitimate user or alternatively that of an intruder.
- **Defines normal, or expected, behavior, to identify malicious or unauthorized behavior.**

## Signature/Heuristic detection

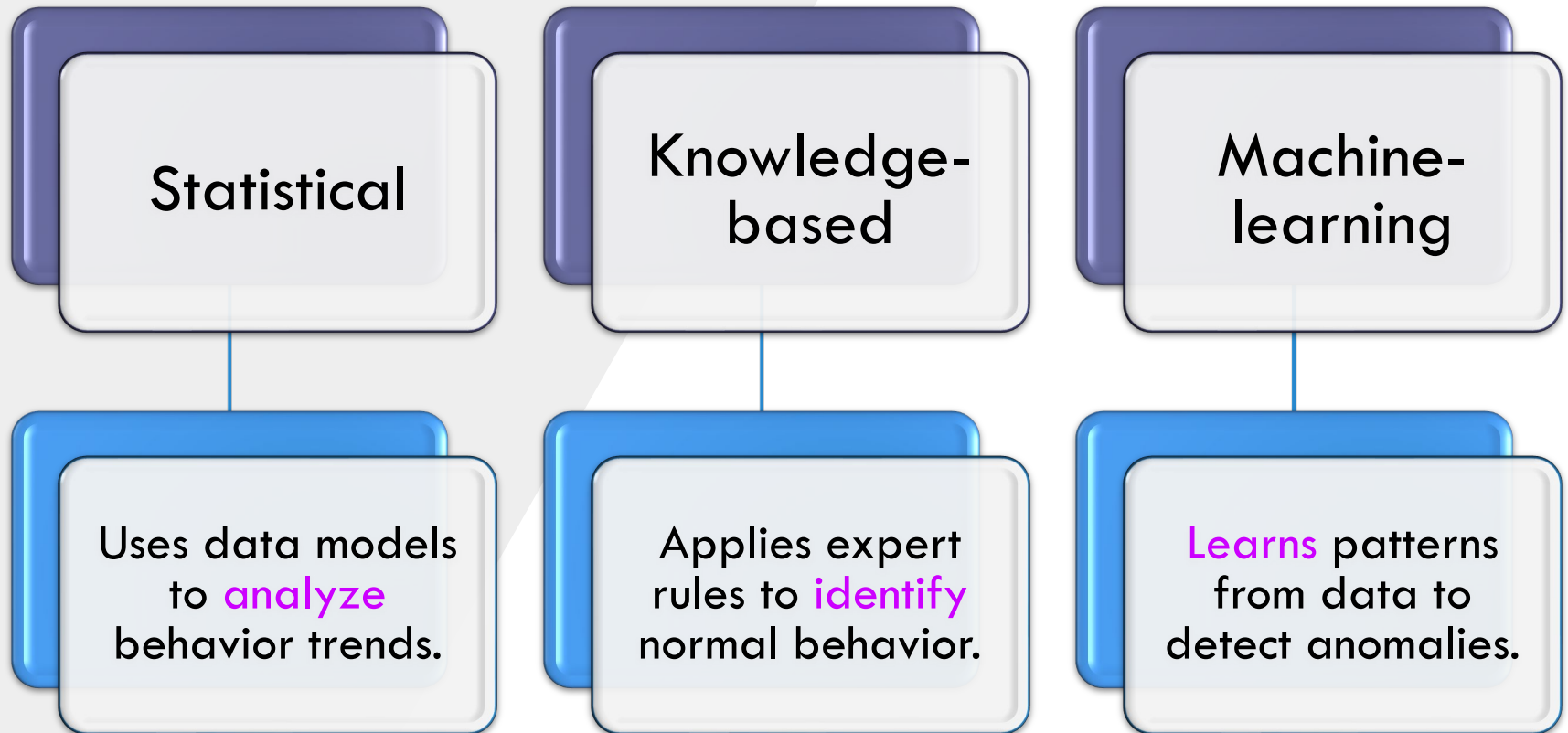
- Uses a set of known malicious data patterns (**signatures**) or attack rules (**heuristics**) that are compared with current behavior to decide if is that of an intruder.
- Known as **misuse detection**.
- Can only identify known attacks for which it has patterns or rules.
- **Defines malicious or unauthorized behavior to quickly and efficiently identify attacks.**

Anomaly detection would be the preferred approach, were it not for the difficulty in collecting and analyzing the data required, and the high level of false alarms

# 1) ANOMALY DETECTION

**Training Phase:** Develop a model of legitimate user behavior by collecting and processing sensor data from the normal operation of the monitored system.

**Detection Phase:** Current observed behavior is compared with the model in order to classify it as either legitimate or anomalous activity in a detection phase.



## 2) SIGNATURE OR HEURISTIC DETECTION

### Signature approaches

- Compares known **malicious patterns to system or network data**. Signatures must balance accuracy and detection. Common in antivirus, network proxies, and **NIDS**.
- **Advantages:**
  - relatively low cost in time and resource use, and its wide acceptance
- **Disadvantages:**
  - Identify new malware to create signatures able to detect it
  - Inability to detect zero-day attacks for which no signatures exist.

## 2) SIGNATURE OR HEURISTIC DETECTION

### Rule-based heuristic identification

- Uses **rules** to detect known attacks or exploit attempts.
- Can also flag suspicious behavior within normal patterns.
- “if-then” logic to spot **unusual activity**

#### Example:

**SNORT** - a rule-based NIDS to detect and alert on potential threats

- If a user tries to log in 10 times in 1 minute, that might be an attack — alert!

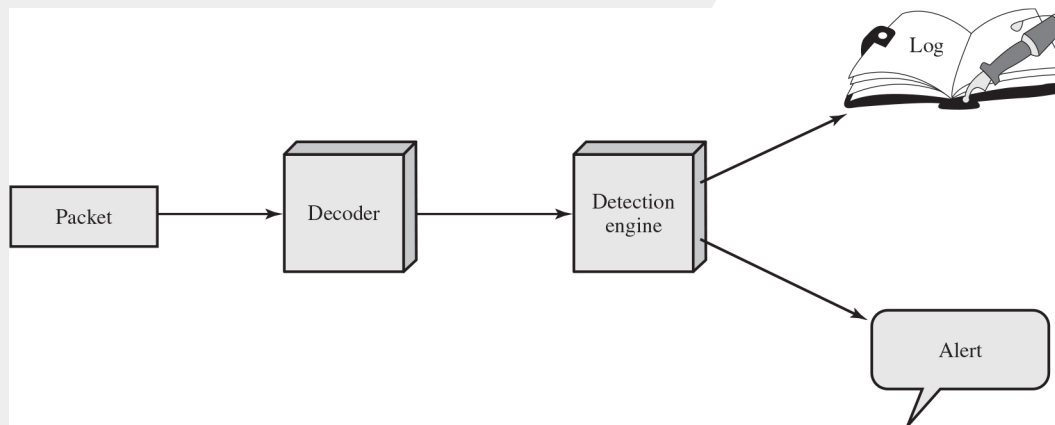
#### Key idea:

It's like a **security guard** who not only knows the faces of known intruders (signatures) but also recognizes **suspicious behavior** even if it's from someone new.



# SNORT ARCHITECTURE

- Snort is an open source, highly configurable and portable host-based or network-based IDS



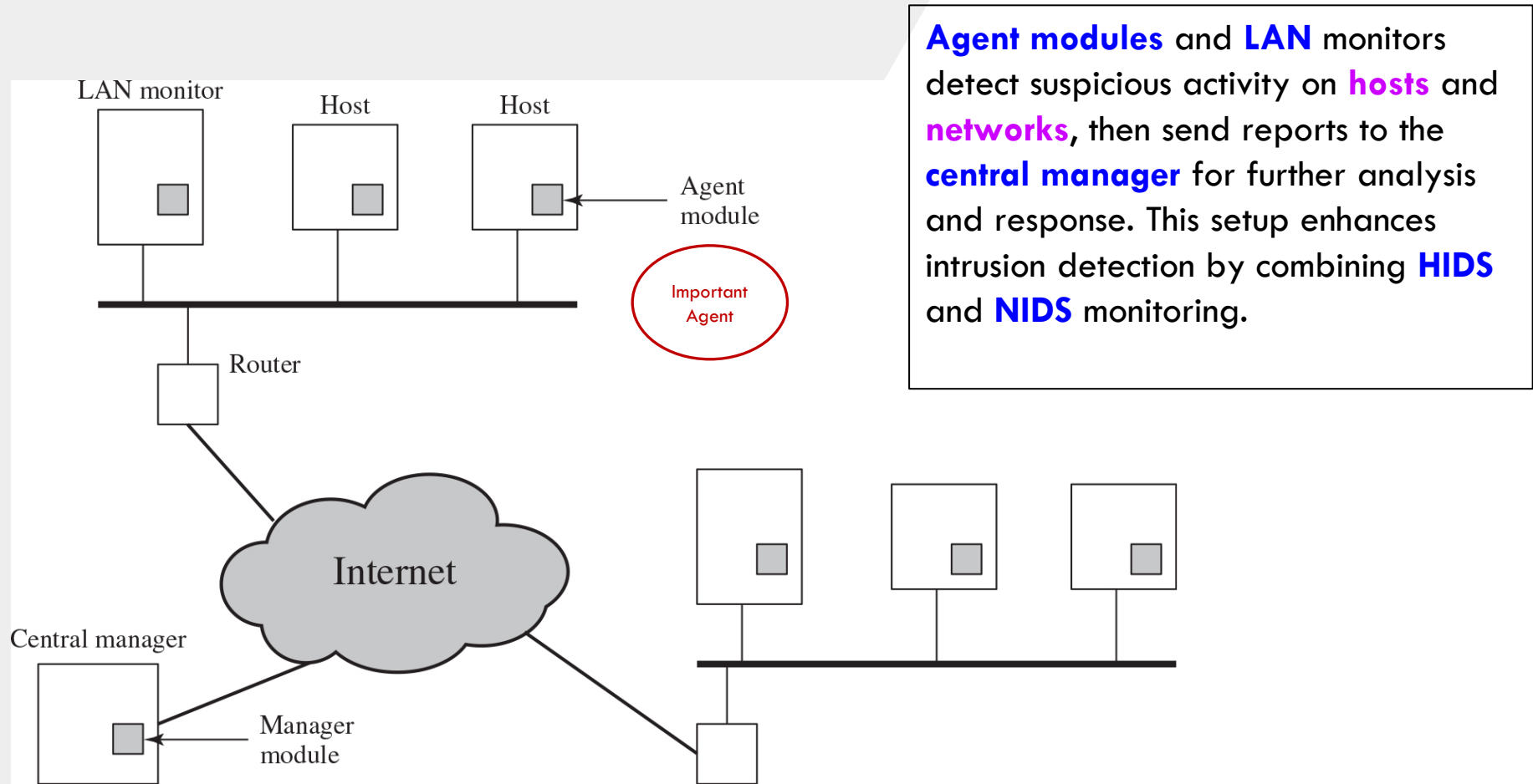
# DATA SOURCES AND SENSORS

- **A fundamental component of intrusion detection is the sensor that collects data**
- **Common data sources include:**
  - System call traces
  - Audit (log file) records
  - File integrity checksums (*signatures*)
  - Registry access

# LOGGING OF ALERTS

- **Typical information logged by a NIDS sensor includes:**
  - Timestamp
  - Connection or session ID
  - Event or alert type
  - Rating
  - Network, transport, and application layer protocols
  - Source and destination IP addresses
  - Source and destination TCP or UDP ports, or ICMP types and codes
  - Number of bytes transmitted over the connection
  - Decoded payload data, such as application requests and responses
  - State-related information

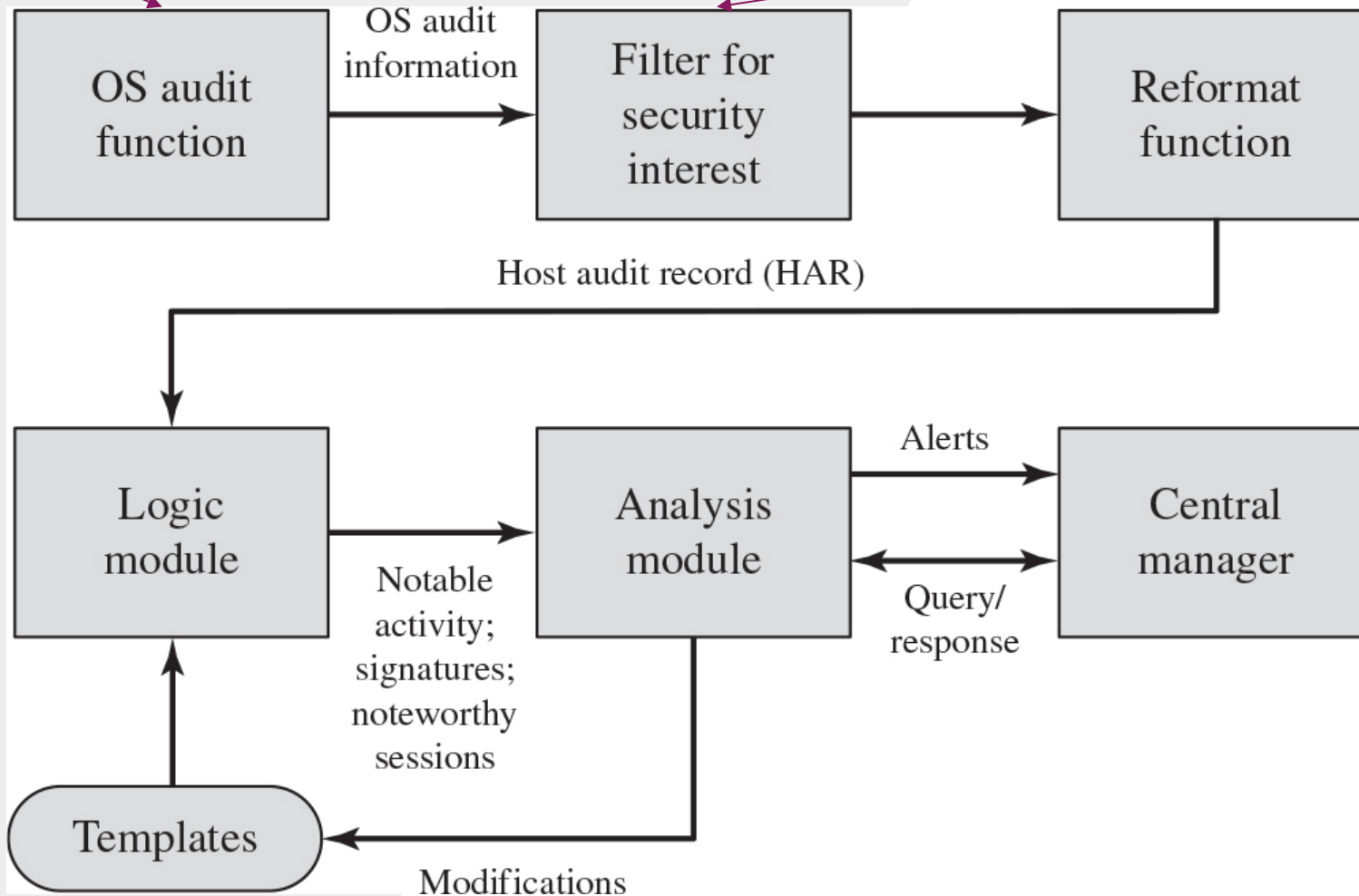
# FIGURE 8.2 ARCHITECTURE FOR DISTRIBUTED INTRUSION DETECTION



# FIGURE 8.3 AGENT ARCHITECTURE

Filters only  
Security related  
logs

Collecting logs

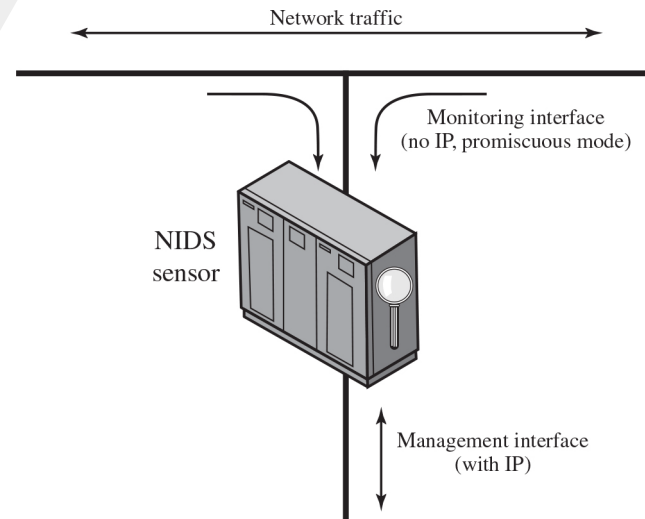


# NETWORK-BASED IDS (NIDS)

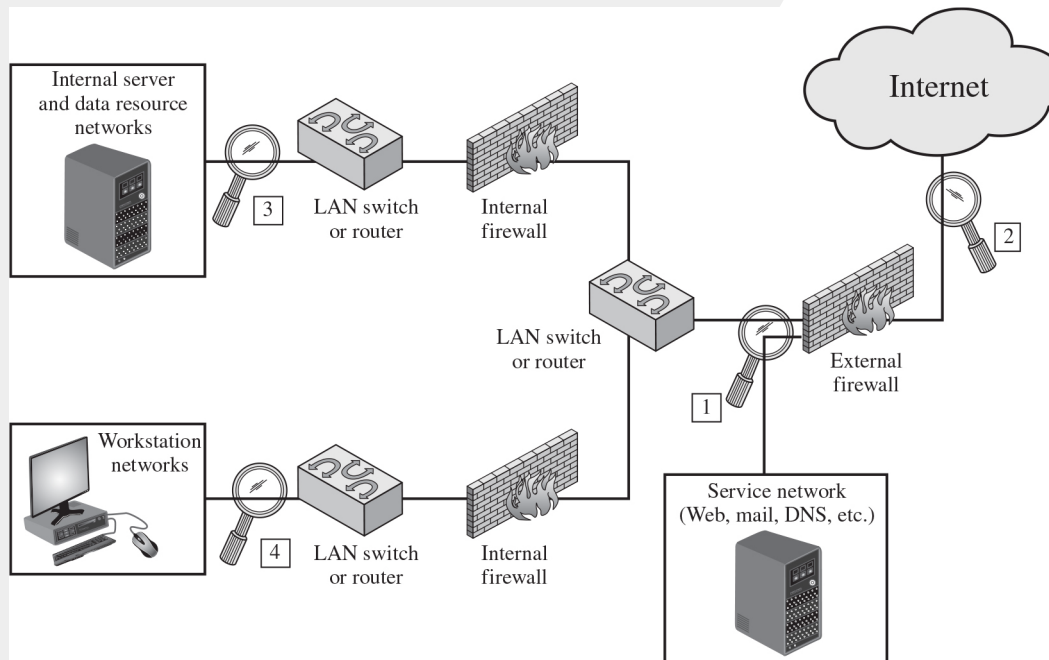
- **Monitors network traffic in real-time, analyzing packets at different protocol levels.**
- **Uses sensors to capture data, servers for NIDS management, and consoles for user interaction.**
- **Traffic analysis can occur at the sensor, server, or both.**

## FIGURE 8.4 PASSIVE NIDS SENSOR

- **Monitoring Interface:** Operates without an IP to passively capture network traffic.
- **Management Interface:** Has an IP address for communication and configuration.
- **Function:** The sensor inspects network traffic in real-time to detect potential threats without interfering with normal data flow.



# FIGURE 8.5 EXAMPLE OF NIDS SENSOR DEPLOYMENT





# STATEFUL PROTOCOL ANALYSIS (SPA)

## NETWORK IDS

- It checks network traffic against predefined normal behavior provided by generic, vendor-provided profiles, instead of learning from an organization's specific traffic patterns.
  - *This helps detect unusual activity based on standard protocol rules.*
- Understands and tracks **network, transport, and application protocol states** to ensure they progress as expected
  - **A key disadvantage is the high resource use it requires**

# HONEYPOTS

- Decoy systems designed to:
  - Lure a potential attacker away from critical systems
  - Collect information about the attacker's activity
  - Encourage the attacker to stay on the system long enough for administrators to respond
- Systems are filled with fabricated information that a legitimate user of the system wouldn't access
- Resources that have no production value
  - Therefore incoming communication is most likely a probe, scan, or attack
  - Initiated outbound communication suggests that the system has probably been compromised

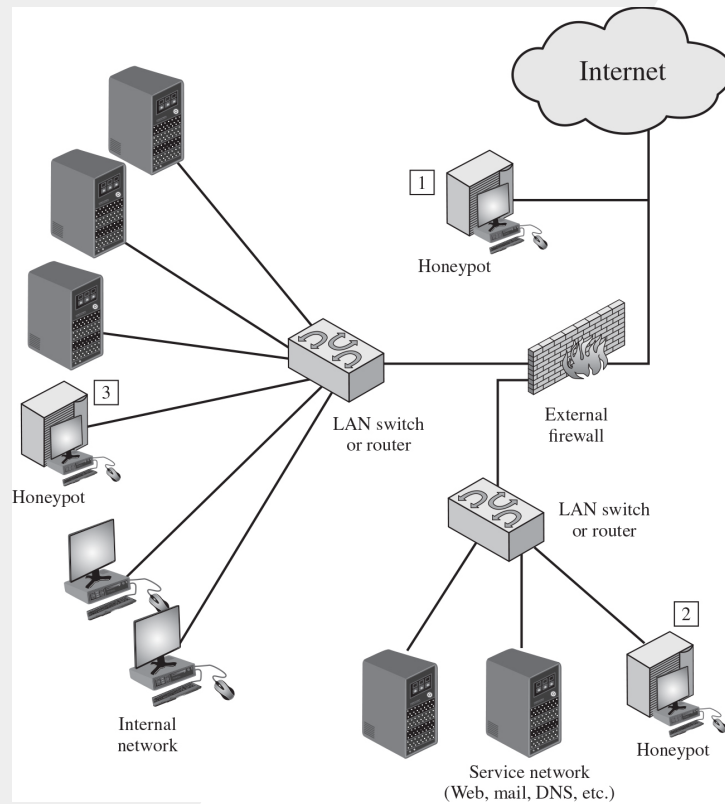
# HONEYPOT CLASSIFICATIONS (1 OF 2)

- Low interaction honeypot
  - Consists of a software package that emulates particular I T services or systems well enough to provide a realistic initial interaction, but does not execute a full version of those services or systems
  - Provides a less realistic target
  - Often sufficient for use as a component of a distributed I D S to warn of imminent attack

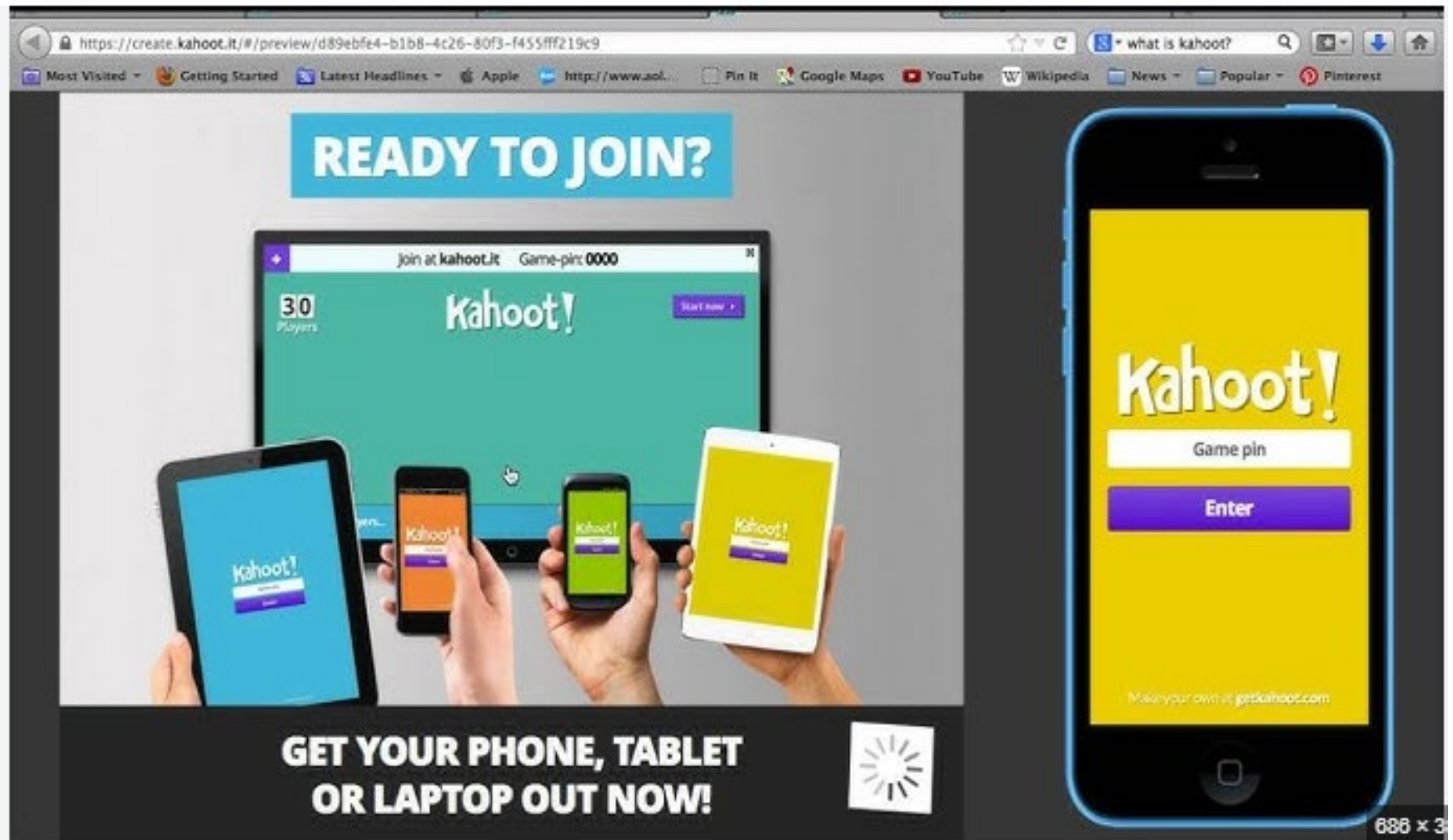
# HONEYPOT CLASSIFICATIONS (2 OF 2)

- High interaction honeypot
  - A real system, with a full operating system, services and applications, which are instrumented and deployed where they can be accessed by attackers
  - Is a more realistic target that may occupy an attacker for an extended period
  - However, it requires significantly more resources
  - If compromised could be used to initiate attacks on other systems

# FIGURE 8.8 EXAMPLE OF HONEYPOT DEPLOYMENT



# Kahoot!



The image displays the Kahoot! website interface within a web browser window and a mobile app interface on a smartphone.

**Website Interface (Left):**

- URL:** <https://create.kahoot.it/#/preview/d89ebfe4-b1b8-4c26-80f3-f455fff219c9>
- Search Bar:** "what is kahoot?"
- Navigation Bar:** Most Visited, Getting Started, Latest Headlines, Apple, http://www.aol..., Pin It, Google Maps, YouTube, Wikipedia, News, Popular, Pinterest.
- Header:** "READY TO JOIN?"
- Main Content:** A large monitor displays the Kahoot! game interface with "30 Players" and "Game-pin: 0000". Below the monitor, four hands hold tablets and smartphones, each displaying the Kahoot! app interface.
- Footer:** "GET YOUR PHONE, TABLET OR LAPTOP OUT NOW!"
- Loading Icon:** A circular loading spinner icon.

**Mobile App Interface (Right):**

- Background:** Yellow.
- Logo:** "Kahoot!" in white.
- Input Field:** "Game pin" with a white border.
- Button:** "Enter" in white on a purple background.
- Footer:** "Make your own at [getkahoot.com](http://getkahoot.com)"

686 x 3

- Which component of an IDS is responsible for collecting raw data from the environment?
  - A. Analyzer
  - B. Sensor
  - C. User interface
  - D. Logger
  - Answer: B. Sensor
- A host-based IDS (HIDS) primarily monitors what?
  - A. Network traffic across the entire LAN
  - B. A single device's logs and activities
  - C. External websites
  - D. Cloud server activities
  - Answer: B. A single device's logs and activities
- Which analysis approach detects intrusions by matching activities to known attack patterns?
  - A. Anomaly detection
  - B. Heuristic analysis
  - C. Signature/heuristic detection
  - D. Behavioral profiling
  - Answer: C. Signature/heuristic detection
- Anomaly detection in IDS is particularly suitable for identifying which type of attacks?
  - A. Application layer reconnaissance
  - B. Denial-of-Service (DoS) attacks
  - C. Policy violations
  - D. Unexpected application services
  - Answer: B. Denial-of-Service (DoS) attacks
- What are the three logical components of an IDS?
  - A. Sensor, Analyzer, and Logger
  - B. Sensor, Processor, and Alert Generator
  - C. Sensor, Analyzer, and User Interface
  - D. Collector, Detector, and Responder
  - Answer: C. Sensor, Analyzer, and User Interface
- Which type of IDS monitors network traffic by analyzing packets in real time?
  - A. Host-based IDS (HIDS)
  - B. Signature IDS
  - C. Network-based IDS (NIDS)
  - D. Behavioral IDS
  - Answer: C. Network-based IDS (NIDS)

- What is a key disadvantage of using signature/heuristic detection methods?
  - A. They generate too many false alarms for internal threats
  - B. They require high computational resources
  - C. They cannot identify new or unknown attacks
  - D. They only work on network traffic
  - Answer: C. They cannot identify new or unknown attacks
- Which open source IDS mentioned in the content can function as both host-based and network-based?
  - A. Bro
  - B. Snort
  - C. Suricata
  - D. OSSEC
  - Answer: B. Snort
- Which of the following is NOT listed as a common data source for IDS sensors?
  - A. System call traces
  - B. Audit (log file) records
  - C. File integrity checksums
  - D. Antivirus signature databases
  - Answer: D. Antivirus signature databases
- What type of information is typically logged by an IDS sensor?
  - A. Hardware specifications and software versions
  - B. Timestamp, session ID, alert type, and protocol details
  - C. User passwords and personal files
  - D. Only the IP addresses of the systems
  - Answer: B. Timestamp, session ID, alert type, and protocol details
- In a distributed IDS architecture, what role do agent modules play?
  - A. They filter incoming network traffic only
  - B. They detect suspicious activity on hosts and networks and report to a central manager
  - C. They replace the need for a central manager
  - D. They only perform data collection
  - Answer: B. They detect suspicious activity on hosts and networks and report to a central manager
- Which IDS technique is more effective against scanning and worm attacks?
  - A. Signature detection
  - B. Anomaly detection
  - C. Protocol analysis
  - D. Heuristic detection
  - Answer: B. Anomaly detection
- What is one of the disadvantages of using stateful protocol analysis in network IDS?
  - A. It ignores application-layer protocols
  - B. It requires extensive resource usage
  - C. It cannot monitor transport layer protocols
  - D. It relies solely on static signatures
  - Answer: B. It requires extensive resource usage



- Signature detection in IDS is particularly suitable for detecting attacks in which layers?

- A. Only the application layer
- B. Application, transport, and network layers
- C. Only the transport layer
- D. Only the network layer

- Answer: B. Application, transport, and network layers

- Which of the following best describes “misuse detection” in an IDS?

- A. Detecting deviations from a user's normal behavior
- B. Identifying threats by comparing current activities with known attack patterns
- C. Logging every user activity regardless of threat level
- D. Encrypting sensitive data during transmission

- Answer: B. Identifying threats by comparing current activities with known attack patterns

- What type of IDS is most likely to use system call traces as a data source?

- A. Network-based IDS (NIDS)
- B. Distributed IDS
- C. Host-based IDS (HIDS)
- D. Hybrid IDS

- Answer: C. Host-based IDS (HIDS)

- C. By solely relying on known attack signatures

- D. By filtering out encrypted traffic

- Answer: A. By comparing behavior to predefined normal profiles

- Which element is NOT part of the typical information logged by an IDS sensor?

- A. Decoded payload data
- B. Network and transport protocol details
- C. Number of bytes transmitted
- D. User personal contact details

- Answer: D. User personal contact details

- What is the primary benefit of using a distributed or hybrid IDS architecture?

- A. It reduces the number of sensors required
- B. It combines host and network data for improved threat detection
- C. It eliminates the need for anomaly detection
- D. It only focuses on internal threats

- Answer: B. It combines host and network data for improved threat detection

- Which of the following is an example of a Linux system call monitored by IDS?

- A. gethostname

- Which element is NOT part of the typical information logged by an IDS sensor?

- A. Decoded payload data
- B. Network and transport protocol details
- C. Number of bytes transmitted
- D. User personal contact details
- Answer: D. User personal contact details

- Which of the following is an example of a Linux system call monitored by IDS?

- A. gethostname
- B. shutdown
- C. unlink
- D. All of the above
- Answer: D. All of the above

- What is the primary benefit of using a distributed or hybrid IDS architecture?

- A. It reduces the number of sensors required
- B. It combines host and network data for improved threat detection
- C. It eliminates the need for anomaly detection
- D. It only focuses on internal threats
- Answer: B. It combines host and network data for improved threat detection

Signature detection in IDS is particularly suitable for detecting attacks in which layers?

- A. Only the application layer
- B. Application, transport, and network layers
- C. Only the transport layer
- D. Only the network layer

Answer: B. Application, transport, and network layers

Which of the following best describes “misuse detection” in an IDS?

- A. Detecting deviations from a user’s normal behavior
- B. Identifying threats by comparing current activities with known attack patterns
- C. Logging every user activity regardless of threat level
- D. Encrypting sensitive data during transmission

Answer: B. Identifying threats by comparing current activities with known attack patterns

Answer: D. User personal contact details

What is the primary benefit of using a distributed or hybrid IDS architecture?

- A. It reduces the number of sensors required
- B. It combines host and network data for improved threat detection
- C. It eliminates the need for anomaly detection
- D. It only focuses on internal threats

Answer: B. It combines host and network data for improved threat detection

Which of the following is an example of a Linux system call monitored by IDS?

- A. gethostname
- B. shutdown
- C. unlink
- D. All of the above

Answer: D. All of the above

# Computer Security: Principles and Practice

## Firewalls and Intrusion Prevention Systems

Chapter 9



# THE NEED FOR FIREWALLS

- Internet access is essential but poses risks.
- Firewalls protect LANs by creating a controlled link between the **internal network and the internet**.
- The firewall is inserted between **the premises network and the Internet** to establish a controlled link and to erect an outer security wall or perimeter.
- They act as a perimeter defense, serving as a single security checkpoint to **monitor, filter, and audit traffic**, **insulating internal systems from external threats**.

A defense mechanism between the LAN and  
Network

# FIREWALL CHARACTERISTICS

- **Design goals**
  - All traffic from inside to outside, and vice versa, must pass through the firewall
  - **Only authorized traffic** as defined by the local security policy will be allowed to pass
  - The firewall itself is immune to penetration

# FIREWALL ACCESS POLICY

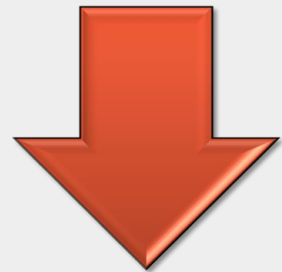
- The primary goal of a firewall access policy is to regulate the flow of traffic based on predefined rules.
- A firewall's access policy defines **authorized traffic** based on **addresses, protocols, applications, and content types**.
- It should be based on the **organization's risk assessment and security needs**, starting with broad traffic requirements and refining them into specific filtering rules within the firewall setup.

# FIREWALL CAPABILITIES AND LIMITS



- **Capabilities:**

- Defines a single choke point
- Provides a location for monitoring security events
- Convenient platform for several Internet functions that are not security related
- Can serve as the platform for IPSec



- **Limitations:**

- **Cannot protect against attacks bypassing firewall**
- May not protect fully against internal threats
- **Improperly secured wireless LAN can be accessed from outside the organization**
- **Laptop, PDA, or portable storage device may be infected outside the corporate network then used internally**



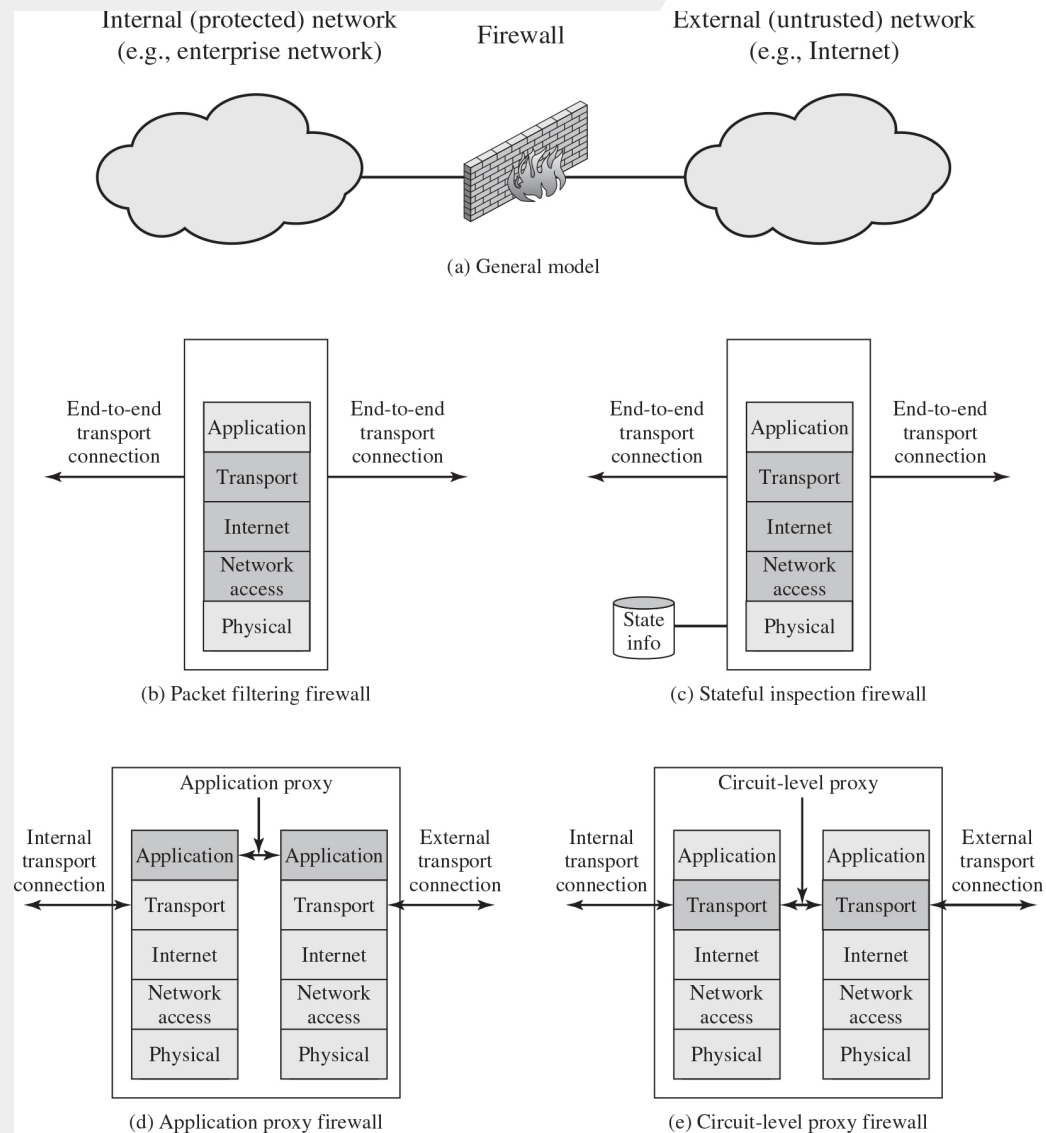
# FIREWALL FILTER CHARACTERISTICS

|                                |                                                                                                                                                                      |
|--------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| IP address and protocol values | <p>This type of filtering is used by <b>packet filter</b> and stateful inspection firewalls</p> <p><b>Typically used to limit access to specific services</b></p>    |
| Application protocol           | <p>This type of filtering is used by an application-level gateway that <b>relays and monitors the exchange of information for specific application protocols</b></p> |
| User identity                  | <p>Typically for <b>inside users</b> who identify themselves using some form of <b>secure authentication technology</b></p>                                          |
| Network activity               | <p><b>Controls access based on considerations such as the time or request, rate of requests, or other activity patterns</b></p>                                      |

# TYPES OF FIREWALLS

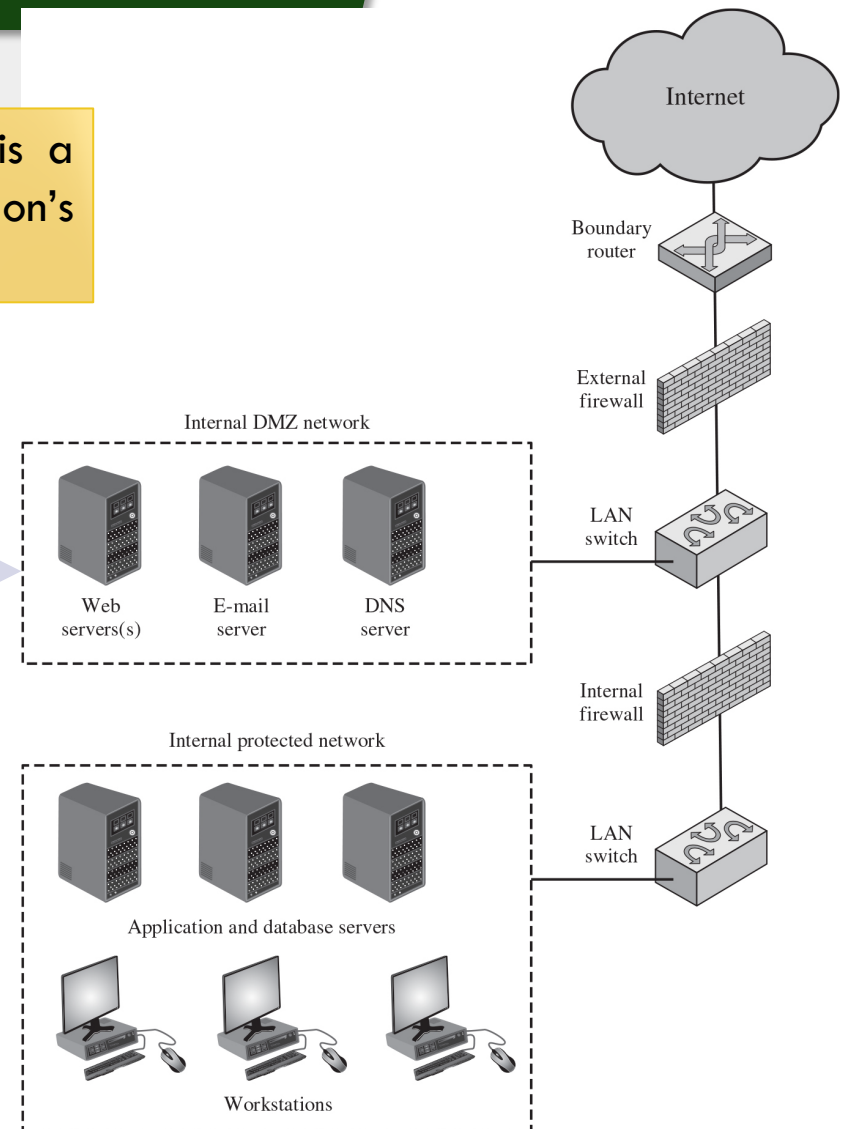
|                              |                                                                                                                                                                                                                                     |
|------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Packet Filtering Firewall    | <ul style="list-style-type: none"><li>• Applies rules to each incoming and outgoing <b>IP packet</b>.</li></ul>                                                                                                                     |
| Stateful Inspection Firewall | <ul style="list-style-type: none"><li>• Tightens rules for TCP traffic by <b>creating a directory of outbound TCP connections</b></li><li>• Reviews packet information but also records information about TCP connections</li></ul> |
| Application-Level Gateway    | <ul style="list-style-type: none"><li>• Also called an application proxy</li><li>• Acts as a relay of application-level traffic</li></ul>                                                                                           |
| Circuit-Level Gateway        | <ul style="list-style-type: none"><li>• Sets up <b>two TCP connections</b>, one between itself and a TCP user on an inner host and one on an outside host (<b>VPN Example</b>)</li></ul>                                            |

# FIGURE 9.1 TYPES OF FIREWALLS



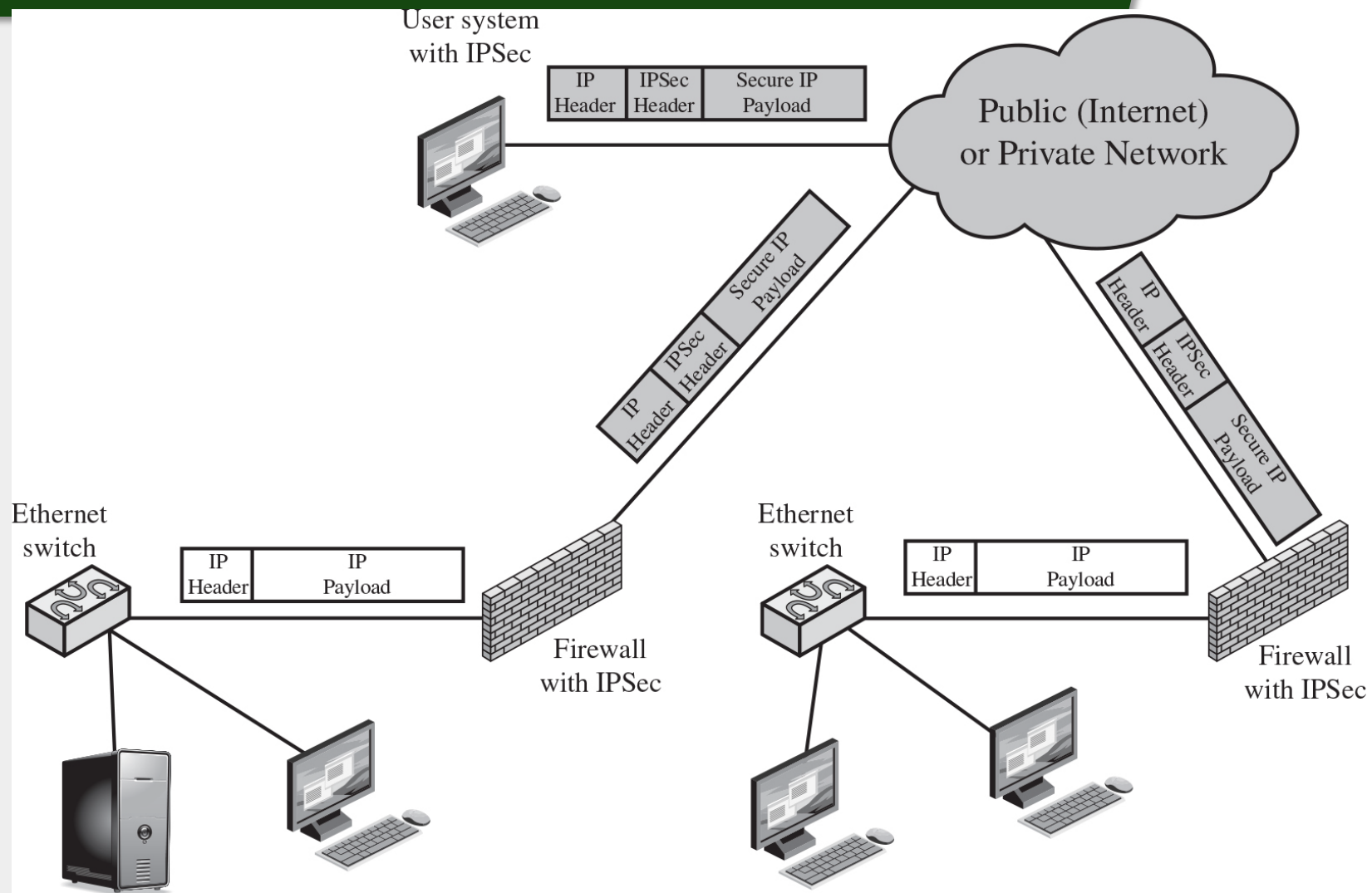
# FIGURE 9.2 EXAMPLE FIREWALL CONFIGURATION

A **DMZ** network (**demilitarized zone network**) is a perimeter network that protects an organization's internal LAN from untrusted traffic

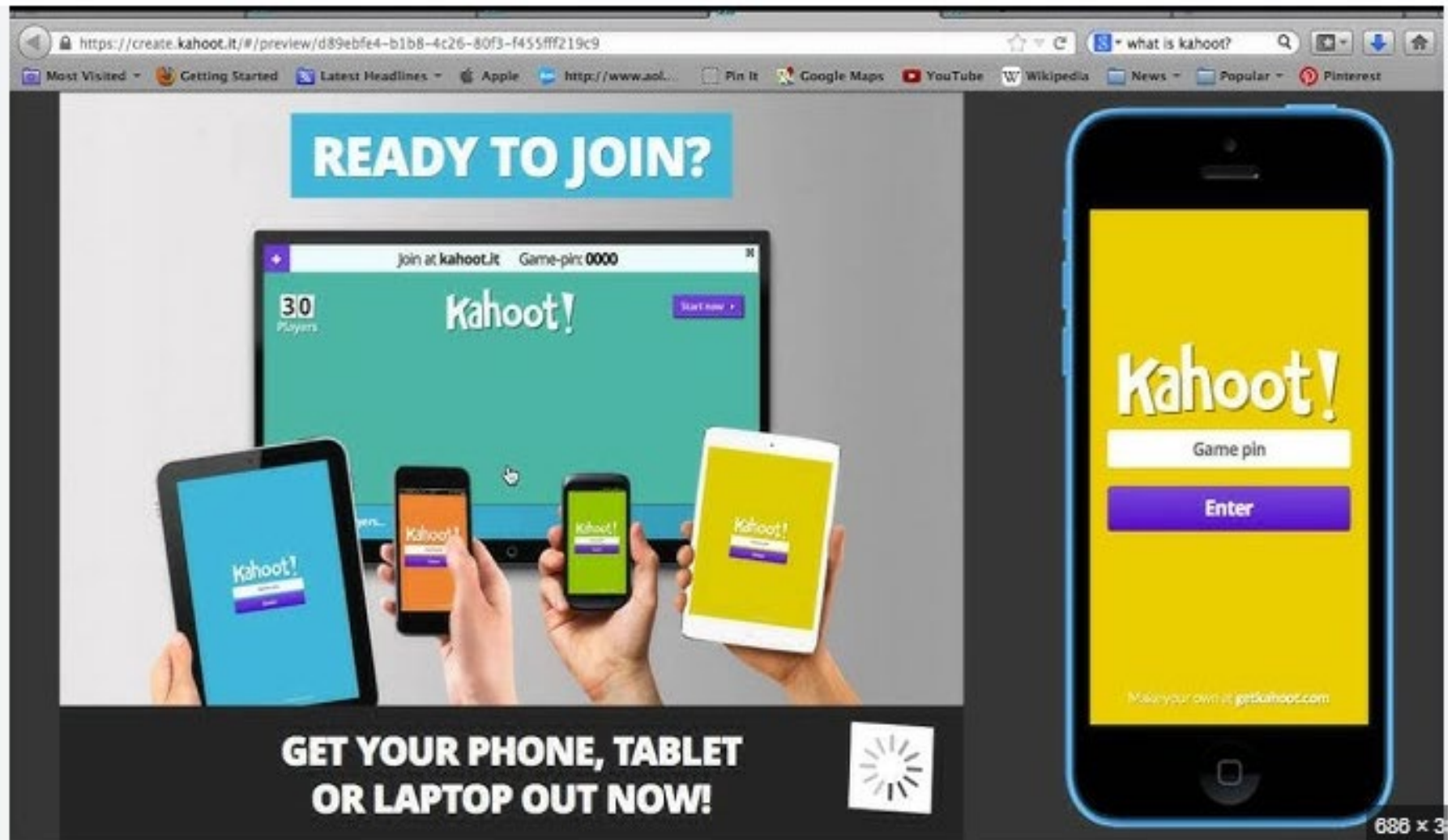


# VPN SECURITY

## FIGURE 9.3 A VPN SECURITY SCENARIO



# Kahoot!



The image displays the Kahoot! website interface across different devices. The top section shows a browser window with the URL <https://create.kahoot.it/#/preview/d89ebfe4-b1b8-4c26-80f3-f455fff219c9>. The browser's address bar and tabs are visible, including "what is kahoot?". The main content area features a large blue banner with the text "READY TO JOIN?". Below this, a laptop screen displays the Kahoot! game interface, showing "30 Players" and a "Start now" button. In front of the laptop, four hands hold various mobile devices (tablet, smartphone, and two more tablets) displaying the Kahoot! app interface. The app interface is yellow with the Kahoot! logo, a "Game pin" input field, and a purple "Enter" button. At the bottom of the app screen, it says "Make your own at getkahoot.com". A black banner at the bottom of the image contains the text "GET YOUR PHONE, TABLET OR LAPTOP OUT NOW!" and a loading icon. The bottom right corner of the image shows the dimensions "686 x 3".

**READY TO JOIN?**

join at [kahoot.it](https://kahoot.it) Game-pin: 0000

**Kahoot!**

30 Players

Start now

**Kahoot!**

Game pin

Enter

Make your own at [getkahoot.com](https://getkahoot.com)

**GET YOUR PHONE, TABLET OR LAPTOP OUT NOW!**

686 x 3